Quantum-Safe in Name Only:

Active Measurement of Post-Quantum Cryptography in Indian Financial Services

P S Lochan
SeQr Labs
contact@seqrlabs.com

2026

Abstract

India's digital-payment infrastructure processes over 13 billion UPI transactions a month, relying extensively on classical public-key cryptography that would be vulnerable to a cryptographically relevant quantum computer (CRQC). To the best of our knowledge, we present the first measurement study of post-quantum cryptography (PQC) adoption across Indian financial-services endpoints, and in doing so identify a methodological problem affecting PQC measurement generally. We make four contributions. **(1) Active vs. passive measurement:** passive TLS scanning—the basis of essentially all prior PQC measurement—reports **0%** hybrid-PQC key exchange across our primary corpus, while **active** probing with an ML-KEM–capable ClientHello confirms **60% (95% CI 47–72)**, demonstrating that passive measurement can systematically undercount PQC deployment. **(2) First Indian-fintech PQC census:** we quantify transport versions, certificate algorithms, key exchange, and PQC adoption across 61 endpoints. **(3) The CDN-edge effect:** the measured PQC is almost entirely a content-delivery-edge default—endpoints behind Amazon CloudFront (95%) and Cloudflare (88%) inherit hybrid PQC, whereas *every directly-hosted origin offers 0% PQC* and **100%** of certificates remain classically signed (RSA/ECDSA). **(4) Origin exposure:** across a broadened 118-domain corpus, **51% (95% CI 42–60) expose a non-CDN origin endpoint** outside the protected edge, so edge PQC is frequently bypassable. PQC has reached Indian fintech not through deliberate migration but largely as an unintended consequence of CDN deployment, leaving authentication, origin servers, and cryptographic inventory unaddressed—precisely the gaps PCI DSS 12.3.3, SEBI's CSCRF, and India's DST quantum-safe roadmap now mandate.

1 Introduction

Shor's algorithm renders RSA and elliptic-curve cryptography insecure against a CRQC [4]. NIST finalised the first PQC standards in August 2024 (FIPS 203 ML-KEM [1], FIPS 204 ML-DSA [2], FIPS 205 SLH-DSA [3]), and a "harvest-now, decrypt-later" (HNDL) adversary can record today's ciphertext for future decryption—making present-day key exchange a present-day exposure for long-lived data [5].

India's regulatory landscape has moved in step. PCI DSS v4.0.1 Requirement 12.3.3 (mandatory since 31 March 2025) requires a documented cryptographic inventory [11]; SEBI's Cybersecurity and Cyber Resilience Framework (CSCRF) added a PQC-migration expectation for regulated entities in June 2025 [12]; and the Department of Science and Technology's February 2026 "Quantum Safe Ecosystem" roadmap targets a cryptographic-asset inventory for critical information infrastructure—which, per NCIIPC, includes banking and financial services—by 2027 [13]. Yet no measurement exists of where Indian financial services actually stand.

We close that gap and, in doing so, surface a measurement-methodology problem that affects the wider field. Our contributions are: **(1)** evidence that passive TLS scanning undercounts hybrid-PQC key-exchange adoption by ∼60 percentage points, with an open active-probe methodology; **(2)** the first PQC census of Indian financial services; **(3)** the finding that measured PQC is explained almost entirely by CDN fronting, not origin migration; and **(4)** a passive origin-discovery analysis showing that half of domains expose a classical origin outside the protected edge.

2 Background and Related Work

Quantum threat. Shor breaks RSA/ECC; Grover halves symmetric security (AES-128 → 64-bit effective, motivating AES-256). A CRQC does not exist today, but HNDL makes quantum-vulnerable key exchange an immediate risk for data with long confidentiality lifetimes.

NIST PQC standards. ML-KEM (FIPS 203) replaces RSA/ECDH key establishment; ML-DSA (FIPS 204) and SLH-DSA (FIPS 205) replace RSA/ECDSA signatures.

Hybrid key exchange. Production deployments pair a classical group with ML-KEM (e.g. X25519MLKEM768) so the shared secret survives if either component does. OpenSSL 3.5 (April 2025) ships these groups natively; major CDNs enabled them by default through 2025.

Indian regulation. PCI DSS 12.3.3 (enforceable 2025-03-31) [11]; SEBI CSCRF PQC expectation (Jun 2025) [12]; RBI Q-SAFE expert committee (constituted May 2026) [14]; DST roadmap (Feb 2026) [13]; DPDP Act 2023 §8 (penalties enforceable 2027-05-13 under the DPDP Rules 2025) [15]. *CNSA 2.0 is US National-Security-System specific and is excluded as inapplicable to Indian private entities.*

Related work. Large-scale TLS measurement is well established—e.g. internet-wide scanning frameworks (ZMap/Censys) [6] and longitudinal HTTPS-ecosystem studies (Holz et al. [7]; Felt et al. [8]; Amann et al. [9])—but these characterise the *classical* TLS ecosystem and predate PQC deployment. PQC-adoption tracking to date relies on *passive* observation: Cloudflare Radar and Google's transparency reporting publish hybrid-PQC adoption from the server/operator side [10], while external surveys infer adoption from advertised parameters. Our work differs in two ways. First, methodologically: we show that purely passive external measurement *systematically misses* server-supported PQC, and that an active ML-KEM ClientHello is required to measure it accurately—a caveat absent from prior external PQC surveys. Second, in scope: no prior measurement study targets Indian financial services, despite their regulatory exposure and transaction volume. We are not aware of prior work that quantifies the gap between edge-advertised PQC and directly-reachable classical origins.

3 Methodology

Corpora. We use two corpora, both curated from NPCI/RBI member lists and transaction-volume rankings, of *endpoints* (API, checkout, and app hosts) rather than only registrable domains:

- **Primary (C1):** 61 Indian financial-services endpoints—payment gateways, UPI apps, brokerages, NBFCs, insurers, and POS/PA providers—with full passive + active TLS measurement. 53 were reachable (87%; the remainder failed DNS resolution); per-endpoint TLS results are reported over $n = 53$.

- **Extended (C2):** 118 domains for the origin-exposure analysis (§4.6), comprising C1 plus 40 additional Indian financial-services domains and a 24-domain international comparison set (US/EU/UK/SG/BR fintech).

Two-phase scanning, one tool. All scans use the SeQr scanner.

- *Passive phase:* sslyze 6.0 enumerates supported TLS versions, cipher suites, and named groups, and parses the leaf certificate—the standard passive methodology.
- *Active phase:* an ML-KEM–capable TLS 1.3 ClientHello (OpenSSL ≥3.5, offering X25519MLKEM768 / SecP256r1MLKEM768 / SecP384r1MLKEM1024 ahead of X25519) records the *negotiated* group, confirming whether the server genuinely performs hybrid PQC.
- *Origin discovery (C2):* for CDN-fronted domains we resolve a fixed list of common ancillary subdomains (`origin.`, `mail.`, `ftp.`, `api.`, `dev.`, `sftp.`, `gateway.`, ...) and classify any resolving to a non-CDN public IP (by published CDN CIDR ranges and reverse DNS) as an exposed origin endpoint. Passive DNS only—candidates are recorded, never scanned.
- All phases: port 443, rate-limited (0.5 s between hosts); no authentication, no application-layer interaction, no exploitation.

Statistics. Proportions are reported with Wilson 95% confidence intervals. TLS results use $n = 53$ (C1); origin-exposure uses $n = 118$ (C2), with the constituent India ($n = 94$) and international ($n = 24$) sub-samples reported separately.

Classification. Quantum-vulnerable: RSA, ECDSA, ECDH, DH, X25519 (Shor). Quantum-weakened: AES-128 (Grover). Quantum-safe / PQC: ML-KEM, ML-DSA, SLH-DSA and their hybrids. Deprecated: SSL 2/3, TLS 1.0/1.1, SHA-1, RSA < 2048.

Ethics. We scanned only public endpoints; every connection is a passive handshake equivalent to a single ordinary client, rate-limited, with no data exfiltration or authentication bypass. Origin discovery is passive DNS resolution of guessed subdomains and does not connect to or scan discovered candidates. This paper reports only aggregate statistics; no entity is named in any weakness-specific claim. Per the venue's disclosure norms, entities with directly-attributable weaknesses are notified before publication, and the identifying dataset is withheld until disclosure completes.

4 Results

4.1 Transport security is modern (C1, $n = 53$). TLS 1.3 on 87% (95% CI 75–93); **zero** legacy TLS (1.0/1.1) or SSL. On transport-version hygiene, Indian fintech is current.

4.2 Authentication is uniformly classical. **100%** of certificates use quantum-vulnerable signatures (95% CI 93–100): RSA-2048 ≈83%, ECDSA-P256 ≈11%, RSA-4096 ≈6%. No PQC (ML-DSA/SLH-DSA) certificate was observed anywhere.

Measurement	Hybrid PQC key exchange	95% CI
Passive (sslyze)	0 / 53 (0%)	0–7
Active (ML-KEM ClientHello)	**32 / 53 (60%)**	47–72

4.3 Key exchange—the central result. Passive measurement detects none; active confirms a majority—a ∼60-point gap, the paper's central methodological finding.

Hosting	Hybrid PQC (active)	95% CI
Amazon CloudFront	18 / 19 (95%)	75–99
Cloudflare	14 / 16 (88%)	64–97
Direct origin (no CDN)	**0 / 18 (0%)**	0–18

4.4 The CDN-edge effect explains it. Every PQC-positive endpoint is CDN-fronted; every directly-hosted origin is classical. PQC adoption here is a provider default, not an organisational decision.

4.5 Forward-secrecy gaps. Key exchange: X25519 ≈85%, ECDHE ≈6%, and **static RSA ≈9% (5/53, 95% CI 4–20)**—these offer no forward secrecy at all, the most exposed configuration in the corpus and exploitable independent of quantum.

4.6 Origin exposure—edge PQC is often illusory (C2, $n = 118$). 51% (60/118, 95% CI 42–60) of domains expose at least one non-CDN origin endpoint (e.g. `api.`, `dev.`, `sftp.` resolving to direct cloud IPs outside the CDN): India 48% (45/94, CI 38–58), international comparison 62% (15/24, CI 43–79). Where the protected edge offers PQC but a directly-reachable origin does not, the edge protection is bypassable. No discovered origin served a PQC certificate.

4.7 Net posture. "60% PQC" describes one hop's key exchange only. Across the layers—100% classical authentication, 0% origin PQC, 0% PQC certificates, and a directly-reachable classical origin for roughly half the corpus—**no endpoint we measured is end-to-end quantum-safe.**

5 Discussion

5.1 Passive measurement is unreliable for PQC. Any "X% PQC" figure from passive external scanning is a lower bound that can understate reality by tens of points. Accurate PQC measurement requires active probing; this generalises well beyond India.

5.2 PQC-by-CDN is real but shallow. Edge hybrid PQC protects only the client $\leftrightarrow$ edge hop. It does not protect edge $\leftrightarrow$ origin, does not make authentication quantum-safe (certificates remain forgeable by a future CRQC), and does not constitute the cryptographic inventory or migration plan regulators require. It is necessary-adjacent, not sufficient.

5.3 Data sovereignty. PQC-positive endpoints terminate TLS at foreign-operated CDN edges—relevant to DPDP Act data-handling and localisation expectations.

5.4 Regulatory gap. None of the measured organisations demonstrably possess a CBOM. PCI DSS 12.3.3 (live), SEBI CSCRF (live), and the DST 2027 milestone all require inventory and migration planning that edge PQC does nothing to satisfy.

6 Limitations

- **(M1) Scale.** C1 is pilot-scale ($n = 53$); we frame it as a first measurement and report all proportions with confidence intervals. Expanding C1 is the priority for a revised version.
- **(M2) Temporal.** Single vantage point and scan window; CDN PQC rollout is dynamic.

- **(M3) Active-probe semantics.** The negotiated group reflects server *preference* given our offered groups; non-negotiation is treated as non-support and may understate edge cases.
- **(M4) Scope.** Certificate-chain, OCSP, and non-443 services are out of scope.
- **(M5) Origins behind CDNs** are, by construction, not externally assessable beyond the exposure analysis of §4.6.

7 Recommendations

- **Entities:** build a CBOM; do not mistake edge PQC for quantum-safety; prioritise certificate agility, the static-RSA endpoints, and exposed origins; plan ML-KEM/ML-DSA at the origin.
- **Regulators (SEBI/RBI/DSCI):** require active-measured PQC evidence, not passive; make a CBOM a near-term examination criterion.
- **Researchers:** adopt active probing as standard for PQC measurement.

8 Conclusion

Indian financial services look modern on transport (TLS 1.3, no legacy) and, by passive measurement, appear to have **no** PQC. Active measurement reverses that to **60%**—but the PQC is an inherited CDN-edge default sitting atop 100% classical authentication, 0% PQC certificates, and a directly-reachable classical origin for half the corpus. The visible progress is real and the underlying exposure is near-total; the measurement methodology is what stands between those two conclusions.

Data and Code Availability

The measured TLS datasets (transport versions, certificate algorithms, key-exchange groups, and active-PQC results) are released at `https://github.com/LochanPS/seqr-labs-research` to support reproduction; the methodology in §3 is described in full. The scanner implementation is proprietary and available on request for academic verification. The raw origin-exposure dataset (which identifies per-entity exposed origin endpoints) is withheld pending responsible disclosure; the aggregate statistic of §4.6 is reported here.

References

[1] NIST. *FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard.* 2024.

[2] NIST. *FIPS 204: Module-Lattice-Based Digital Signature Standard.* 2024.

[3] NIST. *FIPS 205: Stateless Hash-Based Digital Signature Standard.* 2024.

[4] P. W. Shor. Algorithms for quantum computation: discrete logarithms and factoring. *FOCS*, 1994.

[5] M. Mosca. Cybersecurity in an era with quantum computers: will we be ready? *IEEE S&P*, 2018.

[6] Z. Durumeric et al. ZMap: Fast Internet-wide scanning. *USENIX Security*, 2013.

[7] R. Holz et al. The SSL landscape—a thorough analysis of the X.509 PKI. *IMC*, 2011.

[8] A. P. Felt et al. Measuring HTTPS adoption on the web. *USENIX Security*, 2017.

[9] J. Amann et al. Mission accomplished? HTTPS security after DigiNotar. *IMC*, 2017.

[10] Cloudflare. Post-quantum cryptography adoption (Cloudflare Radar), 2024–2025.

[11] PCI Security Standards Council. *PCI DSS v4.0.1, Requirement 12.3.3.* 2024.

[12] SEBI. *Cybersecurity and Cyber Resilience Framework (CSCRF) for Regulated Entities.* 2024; PQC update 2025.

[13] Department of Science and Technology, Govt. of India. *Implementation of Quantum Safe Ecosystem in India—Report of the Task Force.* Feb 2026.

[14] Reserve Bank of India. *Q-SAFE Expert Committee.* Press release, 25 May 2026.

[15] Government of India. *Digital Personal Data Protection Act 2023; DPDP Rules 2025.*

[16] Qualys SSL Labs. *SSL Pulse (global TLS baseline).* 2024.